

Технічні вимоги ЄСІКС

I. Інфраструктурні сервіси

I-1. Інфраструктура безпеки (X.509, EUDI)

I-2. Рольова модель і система доступів (ABAC, IAM)

I-3. Оркестрація процесів (BPMN)

I-4. Словникова підсистема (HL7)

I-5. Мета сервіси схеми даних (SCHEMA)

I-6. Конструктор форм і процесів (X-FORMS)

Зміст

Зміст

1	Інфраструктура безпеки	3
1.1	Провайдери української криптографії	3
1.2	Вимоги до сутностей	4
1.2.1	Директорія (LDAP)	4
1.2.2	Сертифікати (X.509)	4
1.2.3	Користувачі (inetOrgPerson)	4
1.2.4	Організації (organization)	4
1.2.5	Криптографічне повідомлення (CMS X.894)	4
1.2.6	Кваліфікований електронний підпис (ДСТУ 4145)	4
1.2.7	Відкликання і перевірка (OCSP)	4
1.2.8	Мітка часу (TSP)	4
1.2.9	Ключі шифрування та сервісні креденціали	4
1.3	Вимоги до процесів	5
1.3.1	Видача сертифікату (enroll)	5
1.3.2	Автентифікація сертифікатом (check)	5
1.3.3	Відкликання сертифікату (revoke)	5
1.3.4	Оновлення сертифікату (renew)	5
1.3.5	Підпис і верифікація (sign/verify)	5
1.3.6	Шифрування і розшифрування (encrypt/decrypt)	5
1.3.7	Управління секретами (store/retrieve)	5
1.4	Вимоги до серіалізації і сховища	5

2	Рольова модель і система доступів	6
2.1	Вимоги до рольової моделі АВАС	6
2.1.1	Об'єкт доступу	6
2.1.2	Суб'єкт доступу	6
2.1.3	Правило доступу	6
2.2	Вимоги до сутностей АВАС	6
2.2.1	Політики доступу	6
2.3	Вимоги до процесів АВАС	6
2.3.1	Життєвий цикл Політики доступу	6
2.3.2	Точки доступу	7
2.4	Вимоги до сутностей ІАМ	7
2.4.1	Адміністратор організацій	7
2.4.2	Адміністратор структурних підрозділів	7
2.4.3	Адміністратор співробітників	7
2.4.4	Адміністратор користувачів	7
2.5	Вимоги до процесів ІАМ	8
2.5.1	Життєвий цикл Адміністратора	8
2.5.2	Життєвий цикл Організації	8
2.5.3	Життєвий цикл Користувача	8
2.5.4	Життєвий цикл Сесії	8
2.5.5	Життєвий цикл Ролі	8
2.6	Вимоги до рольової моделі ІАМ	8
2.6.1	Точки доступу	8
2.7	Вимоги до сховища	8
2.8	Вимоги до серіалізації і валідації	8
3	Оркестрація процесів	9
3.1	Вимоги до сутностей BPMN	9
3.1.1	Документ	9
3.1.2	Процес	9
3.1.3	Монітор	9
3.1.4	Задача користувача (АРМ)	9
3.1.5	Системна задача	9
3.1.6	Перехід	9
3.1.7	Подія	10
3.1.8	Таймаут	10
3.1.9	Асинхронне повідомлення	10
3.2	Вимоги до процесів	10
3.2.1	Створення	10
3.2.2	Зупинення	10
3.2.3	Відновлення	10
3.2.4	Архівація	10
3.2.5	Зміна контексту процесу	10
3.2.6	Перехід на стадію	10
3.3	Вимоги до сховища	10

4	Словникова підсистема	11
4.1	Загальні відомості	11
4.2	Вимоги до сутностей HL7	11
4.2.1	Системноутворюючі довідники	11
4.2.2	Похідні довідники	11
4.2.3	Система імен	11
4.2.4	Відображення довідників	11
4.2.5	Налаштування довідникової системи	11
4.3	Вимоги до процесів	12
4.3.1	Створення попереднього словника	12
4.3.2	Редагування попереднього словника	12
4.3.3	Публікація словника	12
4.3.4	Деактивація словника	12
4.3.5	Архівування словника	12
4.4	Вимоги до сховища	12
5	Мета сервіси та конструктор	13
5.1	Реєстр сутностей системи (API)	13
5.2	Бібліотека валідації (JSON Schema)	13
5.3	Конструктор сутностей та форм	13
5.4	Конструктор бізнес процесів	13
5.5	Конструктор словників	13
5.6	Конструктор правил доступу	13
5.7	Конструктор шаблонів профілів користувачів	13

Анотація

ТЕХНІЧНІ ВИМОГИ НА СТВОРЕННЯ ЗАСОБУ ІНФОРМАТИЗАЦІЇ - КОМПОНЕНТІВ “КЕРУВАННЯ ДОСТУПОМ”, БАЗОВИХ, БІЗНЕС СЕРВІСІВ ТА ІНФРАСТРУКТУРИ ЄДИНОЇ СУДОВОЇ ІНФОРМАЦІЙНО-КОМУНІКАЦІЙНОЇ СИСТЕМИ.

Вступна частина

Умовні скорочення та визначення

Терміни та скорочення, що використовуються в документі:

Термін	Значення
Автентифікація	Електронна процедура, яка дає змогу підтвердити електронну ідентифікацію фізичної, юридичної особи, інформаційної або інформаційно-комунікаційної системи та/або походження та цілісність електронних даних
Авторизація	Частина процедури визначення та надання прав доступу до функцій та/або інформаційних ресурсів для роботи в інформаційній системі, після автентифікації
Валідація	Встановлення об'єктивних і задокументованих доказів того, що визначені вимоги до спеціально призначеного застосування можна послідовно виконати
API	Автоматизовані програмні інтеграції, відомі також як “прикладний інтерфейс програмування – application programming interface”
БД	База Даних — Організована колекція даних, яка зберігається та управляється з використанням комп'ютерної системи; забезпечує зберігання, організацію та доступ до даних з метою ефективного використання та обробки
БП	Бізнес Процес — Сукупність дій необхідних для здійснення людиною або системою, в результаті яких відбувається досягнення бажаного результату
КЕП	Кваліфікований електронний підпис (X.509)
PMK	Реєстраційно-моніторингова картка
APM	Автоматизоване робоче місце користувача
HSM	Hardware Secured Module
ЄСІКС	Єдина судова інформаційно-комунікаційна система
IAM	Identity and Access Management
SSO	Single Sign-On
BPMN	Business Process Model and Notation (ISO 19510)
ABAC	Attribute-Based Access Control (ISO 29146)
PEP	Policy Enforcement Point (ISO 29146)
PIP	Policy Information Point (ISO 29146)
PAP	Policy Administration Point (ISO 29146)

Загальні положення

Технічні вимоги на основі «Концепції ЄСІКС» від 2024 року [12].

Призначення та цілі впровадження

З метою забезпечення узгодженої, безпечної та ефективної роботи ЄСІКС, а також унеможливлення фрагментації підходів до управління доступом, даними та інфраструктурою, в рамках ЄСІКС є необхідним створення та впровадження централізованих спільних компонентів, зокрема:

1. Інфраструктура безпеки ІАМ: управління доступами, користувачами, організаціями, ролями, ідентифікацією, автентифікацією, авторизацією, фіксація подій доступу.
2. Рольова модель доступів АВАС: централізоване керування правами на основі атрибутів, точок доступу, правил доступу.
3. Оркестрація процесів BPMN: управління документообігом, задачами, переходами, таймаутами, умовами, логікою.
4. Словникова підсистема HL7: системоутворюючі довідники, похідні піддовідники, версіювання, ієрархії, імутабельність.
5. Мета сервіси схеми даних та конструктор форм: конструктор сутностей, форм, бізнес-процесів, словників, правил доступу, шаблонів профілів користувачів.

Реалізація зазначених складових є передумовою побудови цілісної, масштабованої та керованої архітектури ЄСІКС, зниження витрат на розробку та супровід, забезпечення єдиних стандартів безпеки та користувацького досвіду.

1. Інфраструктура безпеки

Інфраструктура відкритого ключа PKI X.509 ДСТУ 4145:2002 передбачає наступний перелік сервісів: CA, CMP, LDAP, CMS, CRL, OCSP, TSP.

1.1. Провайдери української криптографії

В Україні існують наступні провайдери криптографії ДСТУ:

- ТОВ “Інститут Інформаційних Технологій”
- АТ КБ “ПриватБанк” (Open Source)
- ТОВ “Сайфер”
- ТОВ “Автор” (BouncyCastle)

1.2. Вимоги до сутностей

1.2.1. Директорія (LDAP)

Директорія підприємства повинна опиратися на ITU/IETF: 2849, 3296, 3671-3673, 3866, 4510-4518, 4522, 4525, 4526, 4929, 5480, X.519.

1.2.2. Сертифікати (X.509)

Сервер сертифікатів повинен опиратися на ДСТУ 4145:2002 криптографію в стандартних X.509 конвертах і опиратися на стандарти ITU/IETF: 3279, 5755, 7030, X.509.

1.2.3. Користувачі (inetOrgPerson)

Реквізитна частина Користувача повинна бути зафіксована технічним завданням.

1.2.4. Організації (organization)

Реквізитна частина Організації повинна бути зафіксована технічним завданням.

1.2.5. Криптографічне повідомлення (CMS X.894)

Криптографічне повідомлення CMS повинно відповідати стандарту CMS X.894 і підтримувати криптографію ДСТУ 4145:2002.

1.2.6. Кваліфікований електронний підпис (ДСТУ 4145)

КЕП повинен відповідати стандарту CMS X.894 і підтримувати криптографію ДСТУ 4145:2002.

1.2.7. Відкликання і перевірка (OCSP)

У складі інфраструктури PKI X.509 повинен бути сервер перевірки валідності сертифікатів або управління CRL списками.

1.2.8. Мітка часу (TSP)

У складі інфраструктури PKI X.509 повинен бути сервер позначки часу для часової аутентифікації.

1.2.9. Ключі шифрування та сервісні креденціали

Для використання у складі апаратного HSM або програмного комплексу з захищеним сховищем.

1.3. Вимоги до процесів

Над сутностями системи інфраструктура безпеки повинна експонувати наступні процеси.

1.3.1. Видача сертифікату (enroll)

Сервер сертифікатів повинен генерувати сертифікати по PKCS-10 CSR протоколу через TCP/DER або HTTP/DER версії CMP протоколів.

1.3.2. Автентифікація сертифікатом (check)

За допомогою клієнтського сертифікату і сервера часу здійснюється підпис автентифікаційного повідомлення і реєстрація в системі сесій і пристроїв (SSO). Кожен користувач повинен мати змогу побачити свої сесії через систему IAM.

1.3.3. Відкликання сертифікату (revoke)

Система повинна містити процедуру відкликання сертифікату.

1.3.4. Оновлення сертифікату (renew)

Продовження терміну дії сертифікату.

1.3.5. Підпис і верифікація (sign/verify)

На кожному пристрої, який може здійснювати SSO логін повинна бути імплементована бібліотека криптографічних операцій ДСТУ 4145:2002 або ECDSA.

1.3.6. Шифрування і розшифрування (encrypt/decrypt)

На кожному пристрої, який може здійснювати шифрування і розшифрування повинна бути імплементована бібліотека криптографічних операцій ДСТУ 7624:2014, 7564:2014 або AES-GCM-256, AES-CBC-256, XSalsa20-Poly1305, XChaCha20-Poly1305.

1.3.7. Управління секретами (store/retrieve)

Управління ключами шифрування і сервісними кредитенціалами.

1.4. Вимоги до серіалізації і сховища

Сертифікати X.509 описуються ASN.1 X.680 мовою і кодуються X.690 DER серіалізатором. Для токенів Європейської Системи EUDI і їх нод eIDAS використовується CBOR (RFC 8742, 8949, 7049) серіалізація [13]. Сховище повинно бути побудоване на низьколатентних бібліотеках з єдиним простором ключів (LSM-дерева) і кешуванням в пам'яті оскільки сервери сертифікатів є вузьким місцем для всіх залежних сервісів.

2. Рольова модель і система доступів

2.1. Вимоги до рольової моделі АВАС

ЄСІКС реалізує систему керування доступом на основі атрибутів (АВАС) згідно з міжнародним стандартом ISO/IEC 29146:2016 (Information technology — Security techniques — A framework for access management) та рекомендаціями NIST SP 800-162.

2.1.1. Об'єкт доступу

Серед об'єктів системи АВАС повинен бути наступний мінімум:

- Співробітник
- Процес
- Документ

2.1.2. Суб'єкт доступу

Суб'єктами системи можуть виступати будь-які автентифіковані РКІ X.509 користувачі.

2.1.3. Правило доступу

Згідно ISO 29146 правила можуть мати типи, групуватися в політики операціями Булевої алгебри, поєднують суб'єкт і об'єкт авторизації. Правило доступу визначає умови позитивної функції на реквізитній частині об'єкту верифікації і суб'єкту верифікації в точці підключення.

2.2. Вимоги до сутностей АВАС

2.2.1. Політики доступу

Політики доступу представляють набір правил доступу згруповані за певною ознакою.

2.3. Вимоги до процесів АВАС

2.3.1. Життєвий цикл Політики доступу

Створення, редагування, реєстрація і видалення політики доступу.

2.3.2. Точки доступу

Перелік обов'язкових точок доступу в ЄСІКС згідно ISO/IEC 29146 від 2016-06-01 визначених як PEP для BPMN.

- BLOCK Блокування користувача
- SEARCH Пошук документів
- VIEW Перегляд папки
- CREATE Створення документу
- EDIT Редагування форми
- DELETE Видалення процесу
- NEXT Наступний крок процесу
- REJECT Відхилення
- SIGN Підпис
- REGISTER Реєстрація документу
- CANCEL Відхилення
- SEND Відправка
- RECEIVE Отримання
- STATUS Модифікація статусу документу

2.4. Вимоги до сутностей IAM

ЄСІКС повинна мати систему керування доступом згідно з міжнародним стандартом ISO/IEC 27001 Information security management systems, ISO/IEC 24760-1:2019 IT security and privacy — A framework for identity management, ISO/IEC 27018:2019.

2.4.1. Адміністратор організацій

Адміністратор організацій здійснює облік підприємств судової системи.

2.4.2. Адміністратор структурних підрозділів

Адміністратор користувачів здійснює управління структурними підрозділами певного підприємства судової системи.

2.4.3. Адміністратор співробітників

Адміністратор користувачів здійснює управління співробітниками конкретного підприємства судової системи.

2.4.4. Адміністратор користувачів

Адміністратор користувачів здійснює управління користувачів будь-якого підприємства судової системи.

2.5. Вимоги до процесів IAM

2.5.1. Життєвий цикл Адміністратора

Створення, редагування, деактивація адміністраторів системи.

2.5.2. Життєвий цикл Організації

Створення, редагування, деактивація організацій системи.

2.5.3. Життєвий цикл Користувача

Створення, редагування, деактивація користувачів системи.

2.5.4. Життєвий цикл Сесії

Кожен користувач системи повинен мати змогу управляти своїми (SSO X.509) сесіями.

2.5.5. Життєвий цикл Ролі

Ролі системи IAM пов'язані з точками доступу ABAC PER.

2.6. Вимоги до рольової моделі IAM

2.6.1. Точки доступу

Перелік обов'язкових точок доступу в ЄСІКС згідно ISO/IEC 29146 від 2016-06-01 визначених як PER для IAM.

- VIEW Переглянути реєстр користувачів/організацій
- CARD Переглянути картку користувача/організації
- CREATE Створити користувача/організацію
- EDIT Редагувати картку користувача/організацію
- DELETE Деактивувати користувача/організацію

2.7. Вимоги до сховища

Сховище повинно бути побудоване на низьколатентних бібліотеках з єдиним простором ключів (LSM-дерева) і кешуванням в пам'яті оскільки це місце є вузьким місцем для всіх залежних сервісів.

2.8. Вимоги до серіалізації і валідації

Серіалізація повинна відбуватися в JSON, а валідація об'єктів здійснюватися через JSON Schema (draft-07).

3. Оркестрація процесів

3.1. Вимоги до сутностей BPMN

ЄСІКС реалізує систему управління діло-процесами згідно з міжнародним стандартом ISO/IEC 19510 Information technology — Object Management Group Business Process Model and Notation.

3.1.1. Документ

Об'єк похідний від базового документу. Повна таксономія документів і їх реквізитні частини визначаються технічним завданням.

3.1.2. Процес

Процес визначає абстракцію над BPMN XML визначенням процесу, яка має здатність інстанціюватися.

3.1.3. Монітор

Абстракція, що представляє ієрархічну групу процесів для утворення реєстраційно-моніторингової картки документообігу.

3.1.4. Задача користувача (АРМ)

Вузол графа процесу, що представляє собою юридичне підтвердження людського втручання.

3.1.5. Системна задача

Вузол графа процесу, що представляє собою автоматичну задачу.

3.1.6. Перехід

Ребро графа процесу, яке містить функцію на основній мові програмування імплементації або скриптовій мові, що має доступ до контекста процесу (всіх його документів на поточній стадії, і повну історію з документами на кожній стадії).

3.1.7. Подія

Асинхронна зовнішня подія, яка залишає слід в історії.

3.1.8. Таймаут

Подія, яка автоматично виконує певну функцію процесу.

3.1.9. Асинхронне повідомлення

Асинхронна відправка довільного повідомлення в інстанцію процесу.

3.2. Вимоги до процесів

3.2.1. Створення

Реєстрація нової інстанції бізнес-процесу на основі завантаженого XML-визначення за стандартом ISO 19510.

3.2.2. Зупинення

Механізм призупинення виконання поточних задач інстанції процесу зі збереженням її повного стану.

3.2.3. Відновлення

Процедура активації раніше зупиненої інстанції процесу з відновленням виконання з останньої точки збереження.

3.2.4. Архівація

Перенесення даних завершених або неактивних інстанцій процесів до довгострокового сховища для звільнення оперативних ресурсів.

3.2.5. Зміна контексту процесу

Динамічна модифікація внутрішніх даних та метаданих інстанції процесу під час її виконання.

3.2.6. Перехід на стадію

Управління переміщенням токена виконання між вузлами графа процесу відповідно до логіки переходів.

3.3. Вимоги до сховища

Сховище повинно забезпечувати атомарну персистентність стану процесів, низьку затримку доступу та підтримку транзакцій.

4. Словникова підсистема

ЄСІКС реалізує систему управління похідними версіюваними ієрархічними словниками згідно з міжнародним стандартом ISO/IEC HL7.

4.1. Загальні відомості

1. Можливість проведення модернізації довідників без контрактів розробки
2. Підтримка версіювання словників
3. Підтримка ієрархічних словників
4. Розробка ергономічної адміністративної панелі оператора
5. Сумісність з існуючими записами ICC і збереження історичних даних
6. Відповідність міжнародним стандартам ISO
7. Імутабельність даних (ніщо не видаляється з системи)
8. Максимальна повнота (ієрархії, трансляція кодів, валідація)
9. Публічний сервіс для пошуку, перегляду, порівняння, експорту
10. Приватний сервіс адміністраторів і операторів ДСА для редагування і публікації, імпорту

4.2. Вимоги до сутностей HL7

4.2.1. Системноутворюючі довідники

Сутність Code System використовується для системноутворюючих довідників, оригінальних довідників які містять повну множину значень, юридичні підписані довідники без права модифікації, імпортовані з інших систем, унормовані національні переклади, тощо.

4.2.2. Похідні довідники

Сутність Value Set використовується для операційних похідних довідників, що відображаються в медичних інформаційних системах. Вони часто містять підмножини значень існуючих довідників, можуть бути складені з існуючих довідників, а також містити повні переліки значень CodeSystem, але мати іншу атрибутику і призначення.

4.2.3. Система імен

Ідентифікація словників повинна здійснюватися через унікальні OID або URI для забезпечення глобальної унікальності в ЄСІКС.

4.2.4. Відображення довідників

Використання сутності ConceptMap для встановлення відповідності між кодами різних довідникових систем.

4.2.5. Налаштування довідникової системи

Глобальна конфігурація параметрів валідації, кешування часто використовуваних значень та правил версіювання.

4.3. Вимоги до процесів

4.3.1. Створення попереднього словника

Ініціалізація нової чернетки словника для наповнення концептами та атрибутами.

4.3.2. Редагування попереднього словника

Внесення змін до структури, назв або кодів у межах неопублікованої версії словника.

4.3.3. Публікація словника

Надання словнику статусу "Active" та фіксація його імутабельної версії для використання в системі.

4.3.4. Деактивація словника

Припинення використання словника для нових записів зі збереженням доступу для перегляду історичних даних.

4.3.5. Архівування словника

Переміщення застарілих версій словників до архівного сховища згідно з регламентами зберігання даних.

4.4. Вимоги до сховища

Сховище словників повинно підтримувати ієрархічну структуру, імутабельність версій та швидкий пошук за кодами.

5. Мета сервіси та конструктор

5.1. Реєстр сутностей системи (API)

Централізований облік усіх програмних інтерфейсів та сутностей системи з детальним описом їх реквізитної частини.

5.2. Бібліотека валідації (JSON Schema)

Набір схем у форматі JSON Schema для автоматичної перевірки цілісності та коректності вхідних даних.

5.3. Конструктор сутностей та форм

Інструментарій для візуального створення структур даних та відповідних користувацьких інтерфейсів (X-Forms).

5.4. Конструктор бізнес процесів

Графічний редактор для моделювання логіки документообігу та автоматизованих задач у форматі BPMN.

5.5. Конструктор словників

Інтерфейс для керування таксономіями, ієрархіями та наповненню довідникової підсистеми ЄСІКС.

5.6. Конструктор правил доступу

Засіб конфігурації політик ABAC на основі атрибутів суб'єктів та об'єктів доступу.

5.7. Конструктор шаблонів профілів користувачів

Інструмент для визначення набору атрибутів та ролей, що застосовуються до категорій користувачів системи.

Висновок

Перша частина сервісів ЄСІКС «Інфраструктурні сервіси» закладає фундамент єдиного інформаційного простору судової системи України. Впровадження централізованої інфраструктури безпеки (X.509/EUDI), гнучкої рольової моделі на основі атрибутів (ABAC), оркестрації бізнес-процесів за стандартом BPMN та унормованої словникової підсистеми (HL7) забезпечує цілісність, масштабованість та високий рівень захисту даних.

Література

- [1] Міністерство охорони здоров'я України. Технічні вимоги Реабілітація 2.0. Версія 08.08.2024.
- [2] ДСТУ 3973-2000. Система розроблення та постачання продукції на виробництво. Правила виконання науково-дослідних робіт. Загальні положення.
- [3] ДСТУ 3974-2000. Система розроблення та постачання продукції на виробництво. Правила виконання науково-конструкторських робіт. Загальні положення.
- [4] ДСТУ 42010:2018. Інженерія систем і програмних засобів. Опис архітектури.
- [5] Закон України «Про захист інформації в інформаційно-телекомунікаційних системах».
- [6] Закон України «Про захист персональних даних».
- [7] Закон України «Про основні засади забезпечення кібербезпеки України».
- [8] OWASP Foundation. OWASP Top 10: The Ten Most Critical Web Application Security Risks. <https://owasp.org/www-project-top-ten/>.
- [9] NIST Special Publication 800-57 Part 1 Revision 5. Recommendation for Key Management.
- [10] ISO/IEC/IEEE 42010:2022. Systems and software engineering — Architecture description.
- [11] Zachman, J.A. A Framework for Information Systems Architecture. IBM Systems Journal, 1987.
- [12] Концепція ЄСІКС. <https://court.gov.ua/storage/portal/dsa/news/Kontseptsia%20ESIKS.pdf>. 2024
- [13] CBOR/COSE encoding/protocol. <https://tonpa.guru/stream/2024/2024-11-20%20CBOR%20COSE.htm>. 2025